

# Relatorio de auditoria de seguranca

Genexus18MCP - revisao estatica com dados anonimizados - 17/09/2026

## Conclusao executiva

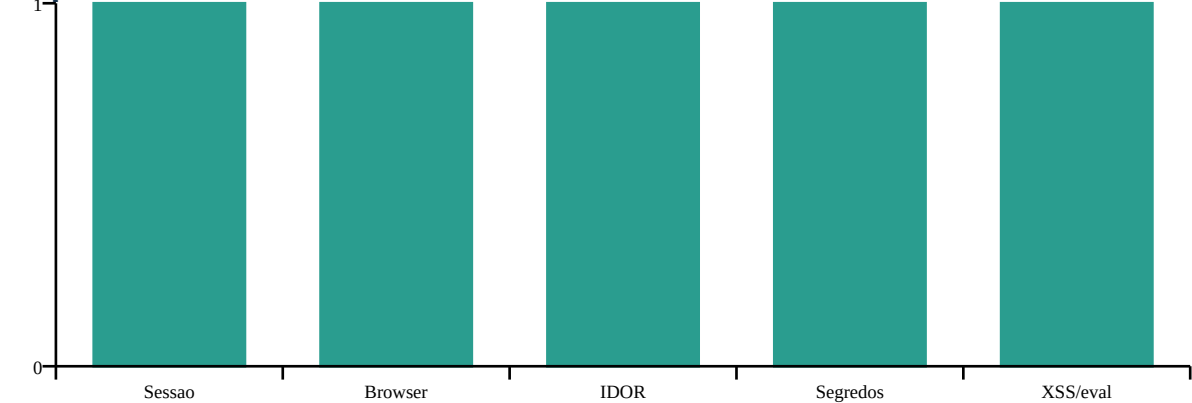
Nenhuma vulnerabilidade foi confirmada nesta rodada. O gateway possui controles de isolamento por sessao e KB, autenticao opcional por token para HTTP, verificacao de Host e Origin, limites de payload, redacao de segredos em logs e filas limitadas. Dois pontos foram registrados como melhoria documental, nao como falhas exploraveis: atualizar a tabela de versoes suportadas em SECURITY.md e explicitar o endpoint HTTP legado no modelo de ameacas.

## Cobertura da revisao

A revisao foi feita sobre a revisao de referencia do upstream e incluiu SECURITY.md, CONTRIBUTING.md, Program.cs, Program.Http.cs, protocolos HTTP MCP, registro de subscriptions, resolucao de KB, routers, dispatcher e CLI. A verificacao cruzada foi feita com Claude Opus em modo somente leitura. Nenhum segredo, token, caminho privado de KB ou dado de cliente foi incluido neste documento.

| Area                      | Resultado  | Evidencia resumida                                                                                          |
|---------------------------|------------|-------------------------------------------------------------------------------------------------------------|
| Isolamento de sessao e KB | Sem achado | Contexto AsyncLocal, leases e resolucao explicita de KB; testes de isolamento existentes.                   |
| Autenticacao e browser    | Sem achado | Token HTTP, Host loopback, Origin allowlist e bloqueio de bind nao-loopback sem token.                      |
| IDOR e selecao de objeto  | Sem achado | Routers delegam a contexto de KB e a operacoes com verificacao de escopo; nenhum bypass reproduzivel.       |
| Segredos e logs           | Sem achado | Redacao de password, token, secret, API key, authorization e credential; token apenas por ambiente.         |
| XSS, eval e bundles       | Sem achado | Nenhum eval ou sink comprovado no caminho MCP auditado; bundle visual de terceiro tratado como dependencia. |

## Mapa de cobertura



1 = area revisada sem vulnerabilidade comprovada nesta rodada.

## Pontos que exigem acompanhamento

1. Atualizar SECURITY.md para refletir a versao/minor realmente suportada, sem declarar uma versao que nao tenha sido validada pelo mantenedor. 2. Documentar explicitamente o endpoint HTTP legado 127.0.0.1:5000/mcp no threat model e no procedimento de hardening. 3. Manter o preflight completo antes de cada push e executar a lane Worker quando o SDK GeneXus estiver instalado no ambiente de validacao.

## Limitacoes e honestidade da evidencia

A auditoria estatica nao substitui teste dinamico contra uma instancia HTTP configurada, um cliente MCP hostil ou uma KB real. A lane Worker nao foi executada localmente porque o SDK GeneXus nao esta instalado neste ambiente. Por

isso o resultado e: nenhum achado comprovado, com validacao operacional do Gateway e pontos documentais pendentes.

## Anexo - issue GitHub

Nao abrir issue de vulnerabilidade: nao houve achado reproduzivel. Registro de melhoria documental para triagem interna:

Titulo: docs(security): atualizar threat model e versao suportada

### ## Contexto

A auditoria estatica de 17/09/2026 encontrou dois pontos documentais: a tabela de versoes de SECURITY.md esta fixa em 3.0.x e o modelo de ameacas nao nomeia o endpoint HTTP legado.

### ## Resultado

Nenhuma vulnerabilidade foi confirmada. O ajuste deve alinhar a documentacao com a configuracao real do release e explicar o hardening do endpoint legado.

### ## Criterios de aceite

- A versao suportada e derivada da politica de release vigente.
- O endpoint legado, token, bind loopback e Origin/Host estao documentados.
- Nenhum segredo ou dado de cliente e incluido.
- Markdown/link checks e preflight passam.